hashlock.

Security Audit

Onramp (DeFi)

Table of Contents

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The Onramp team partnered with Hashlock to conduct a security audit of their smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

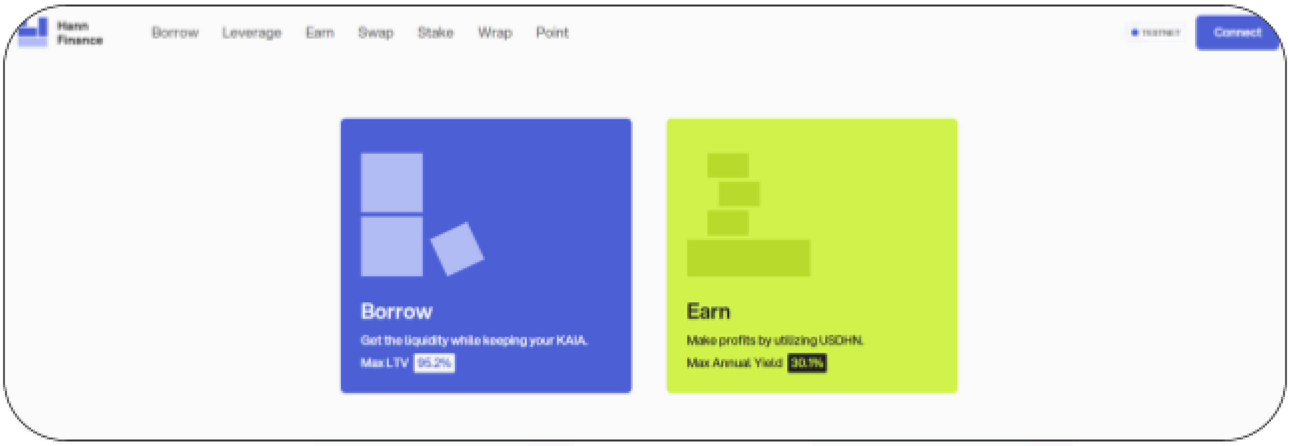
Hann Finance is positioning itself as a stability-first DeFi platform built for the KAIA ecosystem, targeting users familiar with web3 liquidity-markets ("Kaia degens"). The website invites users to join a waitlist and hints that its testnet is already live. It emphasises simplicity and robustness, promising a next-generation source of liquidity with minimal complexity.

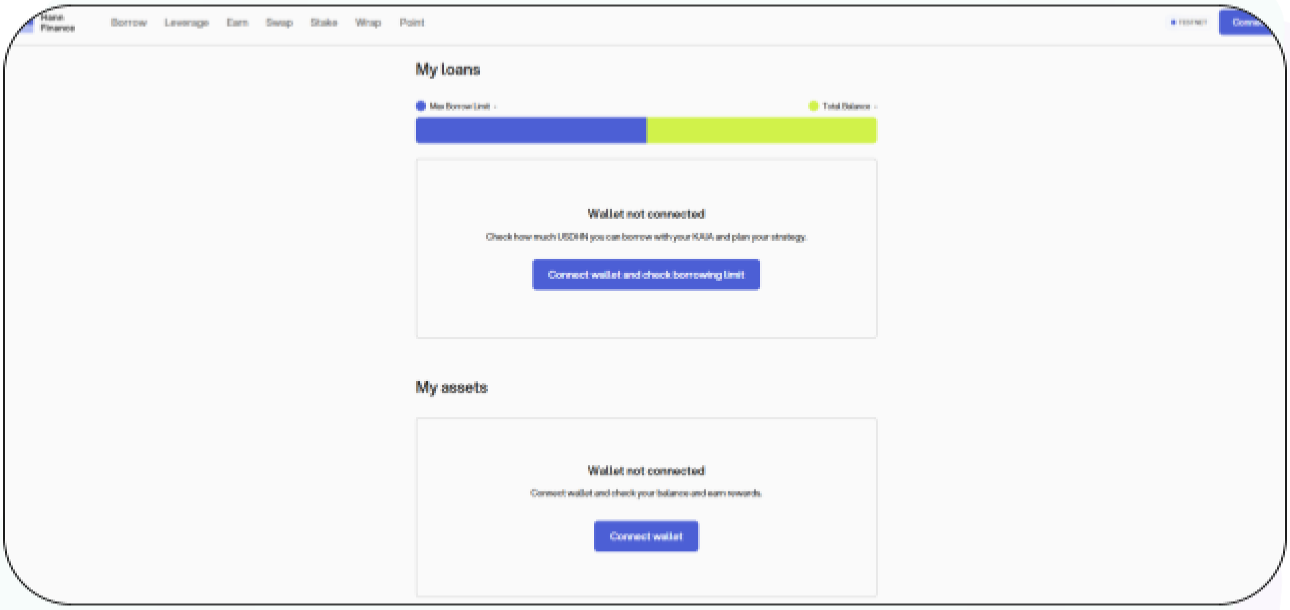
Project Name: Hann Finance
Project Type: Defi
Compiler Version: ^0.8.30
Website: https://hann.finance
Logo:

Visualised Context:

Project Name	**Launch Date**
Hann Finance	TBA
Compiler Version	**Language**
v^0.8.30	SOLIDITY
Network	**Token Ticker**
KAIA	TBA

Project Visuals:





Audit Scope

We at Hashlock audited the solidity code within the Hann Finance project. The scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	**Hann Finance Smart Contracts**
Platform	**KAIA / Solidity**
Audit Date	**November, 2025**
GitHub link1	https://github.com/Hann-Finance/lendingcore
Contract 1	src/KaiaDualSourceOracle.sol
Contract 2	src/OracleRouter.sol
Contract 3	src/WitnetV3Adapter.sol
Audited GitHub Commit Hash	4a0e87326f3c44cdda00bf4376ac9c366585bf60
Fix Review GitHub Commit Hash	cf243017c9ff668ff4c5b7bb6c06942489681481

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Open Zeppelin contracts.

The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on-chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the Audit Findings section. The list of audited assets is presented in the Audit Scope section, and the project's contract functionality is presented in the Intended Smart Contract Functions section.

All vulnerabilities initially identified have now been resolved.

Hashlock found:

2 Medium severity vulnerabilities

Caution: *Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.*

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
Lending-Core(Oracle) • Dual-Oracle System: Provides resilient price feeds by using a primary source (Orakl) with a fallback (Witnet) for redundancy. • Centralized Router: An OracleRouter contract maps assets to specific price feeds, allowing for flexible, owner-managed configuration. • Standardized Interface: Implements Chainlink's AggregatorV3Interface to ensure compatibility with a wide range of oracle providers. • Flexible Integration: Includes a WitnetV3Adapter to make non-standard oracles compatible with the standardized system. • Data Integrity: Enforces data quality by normalizing prices to a consistent number of decimals and checking for stale or invalid data.	**Contract achieves this functionality.**

Code Quality

This audit scope involves the smart contracts of the Hann Finance project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring were recommended to optimize security measures.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Hann Finance project smart contract code in the form of GitHub access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.
Apart from libraries, its functions are used in external smart contract calls.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies.
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue.
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Medium

[M-01] KaiaDualSourceOracle#STALE_AFTER - Single stale threshold for multiple price feed providers

Description

The contract uses a single `STALE_AFTER` parameter to validate staleness for all four price feeds from two different providers (`Orakle` and `Witnet`), despite each provider having significantly different update characteristics and configurations.

Vulnerability Details

The `KaiaDualSourceOracle` contract implements a dual-source oracle pattern using `Orakle` as the primary source and Witnet as the fallback. The contract validates price staleness using a single immutable `STALE_AFTER` parameter that is applied uniformly to all price feeds, regardless of their provider or update characteristics.

According to the provider configurations:

- Orakle feeds have a submitInterval of 60 seconds, meaning prices are expected to update approximately every 60 seconds
- Witnet feeds have a heartbeat threshold of 24 hours and deviation threshold, meaning prices can remain valid for up to 24 hours without updates

Impact

The single stale threshold causes either false rejections of valid `Witnet` prices (if set too low) or acceptance of stale Orakle prices (if set too high), compromising the reliability and accuracy of the dual-source oracle system

Recommendation

Implement separate stale thresholds for each provider by replacing the single `STALE_AFTER` parameter with `STALE_AFTER_ORAKL` and `STALE_AFTER_WITNET`.

Status

Resolved

[M-02] WitnetV3Adapter# - Incorrect decimal handling

Description

The `WitnetV3Adapter` contract only normalizes prices when the decimals variable is set to 8, converting from `Witnet's` native 6 decimals. When decimals is set to any other value (not 6 or 8), the contract returns prices in `Witnet's` native 6 decimals while reporting a different `decimals` value, causing a mismatch between the reported and actual decimal precision.

Vulnerability Details

The `WitnetV3Adapter` contract implements the `AggregatorV3Interface` and is designed to normalize Witnet price feed data. The price normalization logic only handles the case where `decimals == 8`, converting from Witnet's native `6` decimals to `8` decimals.

In all price returning functions `latestRoundData()`, `latestAnswer()`, `getAnswer()`, and `getRoundData()` logic is:

```
if (decimals == 8 && price > 0) {

    price = price * 100; // Convert 6 decimals to 8

}
```

This means:

- If `decimals == 8`: Price is correctly converted from `6` to `8` decimals
- If `decimals == 6`: Price is returned as-is (correct, since `Witnet` uses 6 decimals)
- If `decimals` is any other value: Price is returned in `6` decimals but the contract reports a different decimals value

When integrating contracts query the `decimals()` function and expect prices to be in that decimal format, they will receive prices in `6` decimals instead, leading to incorrect calculations and potential integration failures.

Impact

Contracts integrating with `WitnetV3Adapter` that expect prices in the reported `decimals()` format will receive incorrect values when `decimals` is not `6` or `8`, causing calculation errors, incorrect price comparisons, and potential integration failures.

Recommendation

Implement proper decimal normalization for all cases.

Status

Resolved

Centralisation

The Hann Finance project values security and utility over decentralisation.

The owner executable functions within the protocol increase security and functionality but depend highly on internal team responsibility.

Conclusion

After Hashlock's analysis, the Hann Finance project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:
In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:
Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au
Contact: info@hashlock.com.au

hashlock.